

SIMATS ENGINEERING
ASSESSMENT TOOL 3 – VIVA QUESTIONS

Course:	Code:	CO: CO5
Duration:	Total Marks: 100	Reg No / Name :

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Code of Conduct:

I M.NITHIYASHREE-192421101 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: M.NITHIYASHREE

Instructions: Answer all questions. Each question carries 4 marks.

-
1. How would you evaluate the security posture of a Windows system after identifying multiple open services?
 2. Which factors would you consider when choosing a hacking tool for Windows vulnerability assessment, and why?
 3. How would you evaluate the security risk associated with an exposed RPC service?
 4. Why are Windows Null Sessions considered a security weakness, and how would you assess their impact?
 5. A Windows shared folder allows unauthorized users to access sensitive files. How would you evaluate the severity of this vulnerability?
 6. How would you distinguish between a vulnerable Windows service and a misconfigured Windows service during security testing?
 7. How would you evaluate the effectiveness of information-gathering techniques against a Windows target?
 8. If a Windows vulnerability can be exploited but requires local access, how would you classify its security impact compared with a remotely exploitable vulnerability?
 9. How would you evaluate the security risks of unconnected or unnecessary services running on a Linux system?

10. Why are rhosts and hosts.equiv considered security risks in Linux? How would you evaluate their impact on system security?
11. How would you assess whether an NFS configuration exposes sensitive Linux files to unauthorized users?
12. A Linux file has incorrect permissions that allow unauthorized modification. How would you evaluate the resulting security risk?
13. How would you compare the security impact of weak file permissions with an unpatched Linux vulnerability?
14. How would you evaluate whether a buffer overflow vulnerability in a Linux application is practically exploitable?
15. Which factors would you consider before selecting an exploitation technique for a Linux vulnerability?
16. How would you evaluate the security of a messaging application that stores user credentials or messages insecurely?
17. A web application is vulnerable to SQL injection. How would you evaluate the severity of this vulnerability and its possible consequences?
18. How would you determine whether a web application vulnerability represents a critical security risk or a low-risk finding?
19. How would you evaluate the security of a mobile application using a tool such as MobSF?
20. A mobile application requests unnecessary permissions such as contacts, microphone, and location. How would you evaluate the associated security risk?
21. How would you evaluate the risk of hardcoded API keys or passwords discovered during mobile application analysis?
22. If the same vulnerability is found in both a web application and a mobile application, how would you compare their security impact?
23. How would you select appropriate hacking tools for assessing Windows, Linux, web, and mobile applications?
24. After performing vulnerability exploitation, how would you evaluate whether the exploitation technique actually demonstrates a significant security weakness?
25. You have identified vulnerabilities in Windows, Linux, messaging, web, and mobile applications. How would you prioritize them and prepare a professional security report?

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
-----------------	------------------	----------------------------	-----------------------------	-----------------------------	----------------------------	-------------

Understanding of Problem Context	20	Clearly understands the security problem and accurately identifies vulnerabilities, risks, and requirements	Good understanding of the security problem with minor gaps	Basic understanding; some security requirements or vulnerabilities are unclear	Poor understanding or misinterpretation of the security problem	
Application of Concepts	30	Accurately applies appropriate ethical hacking concepts, tools, and exploitation techniques to analyze complex security problems	Applies relevant security concepts and tools correctly with minor errors	Applies basic concepts with limited accuracy or tool selection	Fails to apply appropriate security concepts or tools	
Problem Solving Approach	20	Demonstrates a logical, well structured, systematic, and efficient approach to identifying and evaluating security weaknesses	Mostly logical and systematic approach with minor gaps	Basic approach with some inconsistencies in vulnerability analysis	Illogical, unclear, or inappropriate approach to solving the security problem	

Accuracy of Solution	20	Provides a completely correct security analysis with appropriate justification, evidence, and suitable prevention	Mostly correct analysis with minor errors or gaps	Partially correct analysis with limited justification	Incorrect or incomplete security analysis	
-----------------------------	-----------	---	---	---	---	--

Clarity	10	techniques. Provi des clear, well-organized, technically sound, and properly explained responses using appropriate security	Understanda ble response with minor clarity or terminology issues	Limited clarity and explanation; uses technical terms inconsistently	Poorly presented, unclear, and difficult to understand	
Total	100	terminology				/100

1. How would you evaluate the security posture of a Windows system after identifying multiple open services?

I would first identify what services are running and whether they are necessary. Then I would check their versions, configurations, authentication controls, and known vulnerabilities. I would assess whether the services are exposed internally or externally and determine their possible impact. Finally, I would prioritize vulnerabilities based on severity and recommend patching, disabling unnecessary services, firewall restrictions, and monitoring.

2. Which factors would you consider when choosing a hacking tool for Windows vulnerability assessment, and why?

I would consider the **type of vulnerability, target environment, accuracy, reliability, safety, reporting capability, and tool compatibility**. I would also ensure that the tool is authorized for the assessment. For example, vulnerability scanners are useful for identifying weaknesses, while specialized assessment tools can validate specific findings. The tool should minimize disruption to production systems.

3. How would you evaluate the security risk associated with an exposed RPC service?

I would check whether the RPC service is necessary, whether it is patched, and whether it is accessible from untrusted networks. I would identify known vulnerabilities and assess authentication and access controls. An exposed and vulnerable RPC service could allow unauthorized access or support privilege escalation and lateral movement, so it should be restricted and monitored.

4. Why are Windows Null Sessions considered a security weakness, and how would you assess their impact?

A Null Session allows certain network information to potentially be accessed without normal authentication. Attackers may use this information for reconnaissance, such as discovering accounts, shares, or system information. I would test whether anonymous enumeration is permitted and determine what information is exposed. The impact is higher if the information can support further attacks.

5. A Windows shared folder allows unauthorized users to access sensitive files. How would you evaluate the severity?

I would examine **what data is accessible, who can access it, whether users can modify or delete it, and whether the data contains sensitive information**. Unauthorized read access is serious, while unauthorized modification of critical files can be even more severe. I would classify the vulnerability based on confidentiality, integrity, and business impact.

6. How would you distinguish between a vulnerable Windows service and a misconfigured Windows service?

A **vulnerable service** contains a security flaw, often related to outdated software or a known vulnerability. A **misconfigured service** may be secure by design but incorrectly configured, such as having excessive permissions or unnecessary network exposure. I would compare the service version and known vulnerabilities with its configuration and access controls.

7. How would you evaluate the effectiveness of information-gathering techniques against a Windows target?

I would determine whether the techniques successfully identify relevant information such as open services, operating-system details, accounts, shares, and network configuration. I would measure the accuracy and completeness of the information gathered and assess whether the information could support further security testing. The techniques should be authorized and performed with minimal impact.

8. If a Windows vulnerability can be exploited but requires local access, how would you classify its security impact compared with a remotely exploitable vulnerability?

A vulnerability requiring local access generally has a **more restricted attack path** than a remotely exploitable vulnerability. A remotely exploitable vulnerability can potentially be attacked without prior access to the system and therefore usually has greater exposure. However, a local vulnerability can still be critical if attackers can obtain an account through phishing, malware, or another vulnerability.

9. How would you evaluate the security risks of unnecessary services running on a Linux system?

I would identify all running services and determine whether each is required. For unnecessary services, I would check their network exposure, permissions, versions, and configurations. Every unnecessary service increases the attack surface. I would recommend disabling unused services and restricting required services through firewalls and access controls.

10. Why are rhosts and hosts.equiv considered security risks in Linux?

They can enable **trust-based authentication**, where certain users or systems may be trusted without requiring strong authentication. If an attacker compromises a trusted host or account, this trust relationship can potentially be abused. I would inspect these files, identify trusted hosts/users, and determine whether the configuration allows unauthorized access.

11. How would you assess whether an NFS configuration exposes sensitive Linux files to unauthorized users?

I would examine the NFS exports and identify which directories are shared and which clients are allowed to access them. I would review permissions, authentication, root access restrictions, and network restrictions. If sensitive directories are unnecessarily exported or accessible to unauthorized hosts, the configuration represents a significant security risk.

12. A Linux file has incorrect permissions that allow unauthorized modification. How would you evaluate the resulting security risk?

I would determine **who can modify the file and what the file controls**. If it is a normal data file, the impact may mainly involve data integrity. If it is a configuration, script, or executable used by a privileged process, unauthorized modification could potentially lead to privilege escalation or system compromise. Therefore, the context of the file determines severity.

13. How would you compare the security impact of weak file permissions with an unpatched Linux vulnerability?

Weak permissions are usually a **configuration weakness**, while an unpatched vulnerability is a flaw in software that may have a known exploitation path. The severity depends on the affected resource and accessibility. An internet-facing critical vulnerability may be more urgent, while writable privileged files could also represent a critical risk.

14. How would you evaluate whether a buffer overflow vulnerability in a Linux application is practically exploitable?

I would first determine whether the vulnerable code is reachable and under what conditions the overflow occurs. I would examine factors such as input control, application privileges, memory protections, and whether reliable exploitation is possible in the authorized test environment. I would also assess the potential impact, such as application crash or unauthorized code execution.

15. Which factors would you consider before selecting an exploitation technique for a Linux vulnerability?

I would consider the **vulnerability type, software version, operating system, required privileges, network accessibility, security controls, potential impact, and likelihood of causing service disruption**. I would select the least disruptive technique necessary to validate the vulnerability and always ensure authorization.

16. How would you evaluate the security of a messaging application that stores user credentials or messages insecurely?

I would examine how credentials and messages are stored, transmitted, and protected. I would check for plaintext storage, weak encryption, insecure APIs, poor authentication, and weak session management. I would also evaluate whether sensitive information can be accessed by unauthorized users. Strong encryption, secure authentication, and protected storage should be implemented.

17. A web application is vulnerable to SQL injection. How would you evaluate the severity and consequences?

I would determine whether the vulnerability allows unauthorized database access and what type of data could potentially be affected. I would assess confidentiality, integrity, and availability

impacts. SQL injection can potentially expose sensitive customer data, modify information, or affect application availability. I would prioritize remediation using parameterized queries, input validation, least-privilege database accounts, and monitoring.

18. How would you determine whether a web application vulnerability represents a critical security risk or a low-risk finding?

I would consider **exploitability, exposure, required privileges, affected data, business impact, and likelihood of exploitation**. An easily exploitable internet-facing vulnerability affecting sensitive information would generally be high or critical. A vulnerability requiring many restrictive conditions with minimal impact would generally be lower risk.

19. How would you evaluate the security of a mobile application using a tool such as MobSF?

I would perform authorized static and, where appropriate, dynamic analysis. I would examine permissions, insecure storage, hardcoded secrets, cryptographic weaknesses, insecure communication, exported components, and API security. I would review the tool's findings, validate important results, assign risk levels, and recommend remediation.

20. A mobile application requests unnecessary permissions such as contacts, microphone, and location. How would you evaluate the risk?

I would determine whether each permission is genuinely required for the application's functionality. Unnecessary permissions increase the potential privacy and security impact if the application or device is compromised. I would recommend following the **principle of least privilege** and requesting only the minimum permissions required.

21. How would you evaluate the risk of hardcoded API keys or passwords discovered during mobile application analysis?

Hardcoded credentials are risky because application packages can potentially be reverse-engineered and inspected. If the credentials provide access to production systems or sensitive APIs, the risk can be high. I would recommend removing secrets from the application,

rotating exposed credentials, using secure server-side secret management, and applying appropriate API authentication.

22. If the same vulnerability is found in both a web application and a mobile application, how would you compare their security impact?

I would not assume that the impact is identical. I would compare **attack surface, affected users, data exposure, authentication mechanisms, exploitability, and business impact**. The web version may be more broadly accessible, while the mobile version may expose locally stored information or device-specific functionality. Risk should be assessed based on the actual implementation and exposure.

23. How would you select appropriate hacking tools for assessing Windows, Linux, web, and mobile applications?

I would first identify the technology and vulnerability type. Then I would select authorized tools appropriate for the environment, such as vulnerability scanners and network-analysis tools for infrastructure, web security testing tools for web applications, and mobile security analysis tools for Android/iOS applications. I would consider **accuracy, safety, compatibility, reporting, and authorization**.

24. After performing vulnerability exploitation, how would you evaluate whether the technique demonstrates a significant security weakness?

I would verify that the result is reproducible and directly related to the identified vulnerability. Then I would determine what access or impact was demonstrated and whether it affects confidentiality, integrity, or availability. I would document evidence without unnecessarily damaging the system and classify the finding according to its actual business impact.

25. You identified vulnerabilities in Windows, Linux, messaging, web, and mobile applications. How would you prioritize them and prepare a professional security report?

I would prioritize vulnerabilities based on **severity, exploitability, exposure, affected assets, sensitive data, and business impact**.

A professional report should contain:

1. Executive summary
2. Scope and methodology
3. Vulnerability description
4. Affected systems
5. Risk/severity rating
6. Evidence
7. Business impact
8. Recommended remediation
9. Priority and timeline
10. Conclusion

Critical vulnerabilities affecting internet-facing systems or sensitive information should normally receive the highest remediation priority.